ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

BÁO CÁO BÀI TẬP LỚN

NGHIÊN CỨU CƠ CHẾ XÁC THỰC VÀ QUẢN LÝ CHỨNG THƯ SỐ X.509 TRONG PKI

Kiến trúc, Chuỗi tin cậy và Đánh giá thực nghiệm

Học phần:	Mật mã và An toàn thông tin
Mã lớp học phần:	2627I_INT3230_2
Thành viên thực hiện:	Đoàn Văn Tuyền (MSSV: 23020151)
	Vũ Minh Quân (MSSV: 23020142)
	Nguyễn Chi Tú (MSSV: 23020148)
Học kỳ / Năm học:	Học kỳ I, Năm học 2026–2027

Hà Nội, Tháng 10/2026

Tóm tắt

Cần viết sau khi có kết quả thực nghiệm: nêu vấn đề, phương pháp, số ca kiểm thử, kết quả quan sát và đóng góp thực tế của nhóm trong khoảng 150–250 từ.

Abstract

To be written after the experiment: summarize the research question, method, observed results, and limitations.

Mục lục

Tóm tắt i

Abstract ii

1 Giới thiệu và xác định vấn đề nghiên cứu 1

1.1 Bối cảnh và bài toán . . . 1

1.1.1 Bối cảnh mật mã khóa công khai . . . 1

1.1.2 Quá trình trao đổi khóa trong điều kiện bình thường . . . 2

1.1.3 Cuộc tấn công thay thế khóa của Eve . . . 2

1.1.4 Phân tích bản chất bài toán và vai trò của PKI . . . 3

1.2 Mục tiêu và câu hỏi nghiên cứu . . . 6

1.3 Phạm vi và phương pháp nghiên cứu . . . 7

1.4 Cấu trúc của báo cáo . . . 7

2 Cơ sở mật mã khóa công khai và PKI 9

2.1 Yêu cầu bảo mật và quản lý khóa . . . 9

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI . . . 9

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã . . . 10

2.2 Khóa công khai, hàm băm và chữ ký số . . . 11

2.3 Vai trò thuật toán trong TLS . . . 14

3 Kiến trúc PKI và vòng đời chứng thư 16

3.1 Thành phần và mô hình tin cậy . . . 16

3.1.1 Các thành phần cốt lõi trong PKI . . . 16

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model) . . . 17

3.2 Vòng đời chứng thư . . . 19

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư . . . 19

3.2.2 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành . . . 24

3.3 Chính sách vận hành . . . 25

3.3.1 Phân định vai trò giữa CP và CPS . . . 25

3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647) . . . 26
3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647) . . . 26
3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647) . . . 27
3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm . . . 27

4 X.509, chuỗi tin cậy và cơ chế xác thực 29
4.1 Cấu trúc chứng thư X.509 v3 . . . 29
4.2 Xây dựng và xác minh đường dẫn . . . 29
4.3 Thu hồi và trạng thái chứng thư . . . 29
4.4 Liên hệ TLS . . . 29

5 Phân tích bảo mật, mô hình tấn công và so sánh 30
5.1 Tài sản, đối thủ và rủi ro . . . 30
5.2 So sánh các cơ chế tin cậy và thu hồi . . . 30
5.3 Giới hạn của chữ ký hợp lệ . . . 30

6 Thiết kế và đánh giá thực nghiệm 31
6.1 Giả thuyết và môi trường . . . 31
6.2 Mô hình và quy trình . . . 31
6.3 Test cases và kết quả . . . 31
6.4 Thảo luận và hạn chế . . . 32

7 Ứng dụng và hướng phát triển PKI 33
7.1 Ứng dụng và Certificate Transparency . . . 33
7.2 Tự động hóa và hậu lượng tử . . . 33

Kết luận và hướng phát triển 34

Danh sách bảng

2.1 Phân định phạm vi hỗ trợ của PKI đối với mục tiêu an ninh thông tin . . 10
2.2 So sánh bản chất và vai trò của các thành phần mật mã trong PKI 13
2.3 Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3 15
3.1 Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI. . . 18
3.2 Phân biệt bản chất kỹ thuật giữa CSR và chứng thư số X.509 24
3.3 So sánh đối chiếu giữa khung RFC 3647, CA thực tế và bài lab 28
6.1 Bộ kiểm thử dự kiến; cột quan sát chỉ điền sau khi chạy lab 31

Danh sách hình vẽ

1.1 Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve. 4
3.1 Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp. 19
3.2 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư X.509 20

Chương 1

Giới thiệu và xác định vấn đề nghiên cứu

Chương này trình bày bối cảnh ra đời của mật mã khóa công khai, phân tích lỗ hổng cố hữu trong phân phối khóa trần qua kịch bản tấn công người đứng giữa (MITM), từ đó dẫn dắt đến sự cần thiết của Hạ tầng khóa công khai (PKI). Tiếp đó, chương xác định rõ mục tiêu, 4 câu hỏi nghiên cứu (RQ1–RQ4), phạm vi triển khai và phương pháp luận của đề tài.

1.1 Bối cảnh và bài toán

1.1.1 Bối cảnh mật mã khóa công khai

Trong các hệ thống thông tin hiện đại, việc truyền thông qua các mạng công cộng như Internet luôn đối mặt với nguy cơ bị nghe lén, can thiệp và sửa đổi dữ liệu. Mật mã khóa công khai (Public-Key Cryptography hay mật mã bất đối xứng) ra đời như một bước đột phá quan trọng nhằm giải quyết hạn chế cốt tử của mật mã đối xứng: bài toán phân phối trước một khóa bí mật chung qua kênh truyền an toàn. Trong mật mã khóa công khai, mỗi thực thể tham gia sở hữu một cặp khóa có quan hệ toán học chặt chẽ nhưng không thể suy dẫn khóa này từ khóa kia với năng lực tính toán thực tế:

- **Khóa công khai (Public Key):** Ký hiệu là PU (theo quy ước kinh điển) hoặc PK (theo chuẩn mật mã học hiện đại). Khóa này được công bố rộng rãi cho mọi đối tượng trong hệ thống mà không cần giữ bí mật.
- **Khóa bí mật (Private Key / Secret Key):** Ký hiệu tương ứng là PR hoặc SK. Khóa này được chủ sở hữu lưu giữ tuyệt đối bí mật và không bao giờ tiết lộ cho bất kỳ ai.

Quy ước ký hiệu cặp khóa: Trong toàn bộ báo cáo này, hai hệ ký hiệu cặp khóa (PU, PR) (Public Key / Private Key) và (PK, SK) (Public Key / Secret Key) được hiểu hoàn toàn tương đương nhau về bản chất mật mã học. Nhằm giữ tính trực quan và gắn liền với kịch bản truyền thông kinh điển giữa các chủ thể (Alice, Bob và Eve), Chương 1 sử dụng hệ ký hiệu (PU_B, PR_B) và (PU_E, PR_E). Từ Chương 2 trở đi, khi đi sâu vào đặc tả kỹ thuật thuật toán, cấu trúc chứng thư X.509 và giao thức TLS 1.3, tài liệu sử dụng thống nhất ký hiệu chuẩn mực (PK, SK) (ví dụ: SK_{CA}, PK_{server}).

Xét kịch bản trao đổi thông tin kinh điển: **Alice** là bên gửi thông điệp, **Bob** là bên nhận thông điệp, và **Eve** là đối thủ tiềm tàng có khả năng giám sát, đánh chặn hoặc sửa đổi các gói tin lưu thông trên mạng. Để gửi một thông điệp bí mật đến Bob, Alice cần sử dụng khóa công khai của Bob để mã hóa. Tuy nhiên, một bài toán then chốt xuất hiện: *Làm thế nào để Alice xác minh rằng khóa công khai mà mình nhận được qua mạng thực sự thuộc về Bob, chứ không phải do đối thủ Eve giả mạo?*

1.1.2 Quá trình trao đổi khóa trong điều kiện bình thường

Trong điều kiện lý tưởng, khi kênh truyền thông không bị can thiệp và khóa công khai được chuyển giao một cách toàn vẹn:

1. Bob khởi tạo cặp khóa cá nhân gồm khóa công khai PU_B và khóa bí mật PR_B.
2. Bob cung cấp khóa công khai PU_B cho Alice qua kênh mạng.
3. Alice sử dụng khóa công khai PU_B của Bob cùng hàm mã hóa $E(\cdot)$ để mã hóa thông điệp M, tạo thành bản mã C:
$$C = E(PU_B, M) \tag{1.1}$$
4. Bob nhận bản mã C và sử dụng khóa bí mật duy nhất tương ứng PR_B cùng hàm giải mã $D(\cdot)$ để khôi phục lại thông điệp gốc M:
$$M = D(PR_B, C) \tag{1.2}$$

Mối quan hệ toán học giữa hai quá trình được tóm lược bằng biểu thức:

$$C = E(PU_B, M), \qquad M = D(PR_B, C). \tag{1.3}$$

Quy trình này chỉ đạt được mục tiêu bảo mật dự kiến khi hai điều kiện tiên quyết được thỏa mãn đồng thời: (1) Alice nhận đúng khóa công khai PU_B của Bob, và (2) giao thức cùng thuật toán mã hóa được sử dụng là an toàn. Nếu Alice bị lừa sử dụng một chiếc khóa khác, tính bí mật của toàn bộ thông điệp sẽ bị vô hiệu hóa hoàn toàn.

1.1.3 Cuộc tấn công thay thế khóa của Eve

Khi việc phân phối khóa công khai diễn ra trên kênh truyền mở mà thiếu cơ chế xác thực nguồn gốc, đối thủ Eve có thể thực hiện một cuộc tấn công thay thế khóa theo phương thức người đứng giữa (*Man-in-the-Middle - MITM*). Giả sử Eve sở hữu một cặp khóa của riêng mình gồm khóa công khai PU_E và khóa bí mật PR_E. Cuộc tấn công diễn ra theo trình tự 6 bước:

1. Bob gửi khóa công khai PU_B của mình cho Alice qua mạng.
2. Eve chặn thông điệp chứa PU_B trên đường truyền và thay thế bằng khóa công khai của mình là PU_E.

3. Alice nhận được PU_E nhưng nhầm tưởng đó là khóa của Bob; do đó Alice sử dụng PU_E để mã hóa thông điệp M:

$$C_1 = E(PU_E, M) \tag{1.4}$$

4. Alice gửi bản mã C_1 đi. Eve chặn bắt C_1 và sử dụng khóa bí mật PR_E của mình để giải mã:

$$M = D(PR_E, C_1) \tag{1.5}$$

Tại thời điểm này, Eve đọc được trọn vẹn nội dung thông điệp gốc M của Alice.

5. Để duy trì sự ngụy trang, Eve sử dụng khóa công khai thật sự của Bob (PU_B) để mã hóa lại thông điệp M:

$$C_2 = E(PU_B, M) \tag{1.6}$$

sau đó Eve chuyển tiếp bản mã C_2 tới Bob dưới danh nghĩa Alice.

6. Bob nhận được C_2, sử dụng khóa bí mật PR_B của mình để giải mã:

$$M = D(PR_B, C_2) \tag{1.7}$$

Bob khôi phục được đúng thông điệp M ban đầu và hoàn toàn không nhận ra cuộc tấn công nếu không có cơ chế xác thực thích hợp.

Ý nghĩa của các biểu thức trong cuộc tấn công:

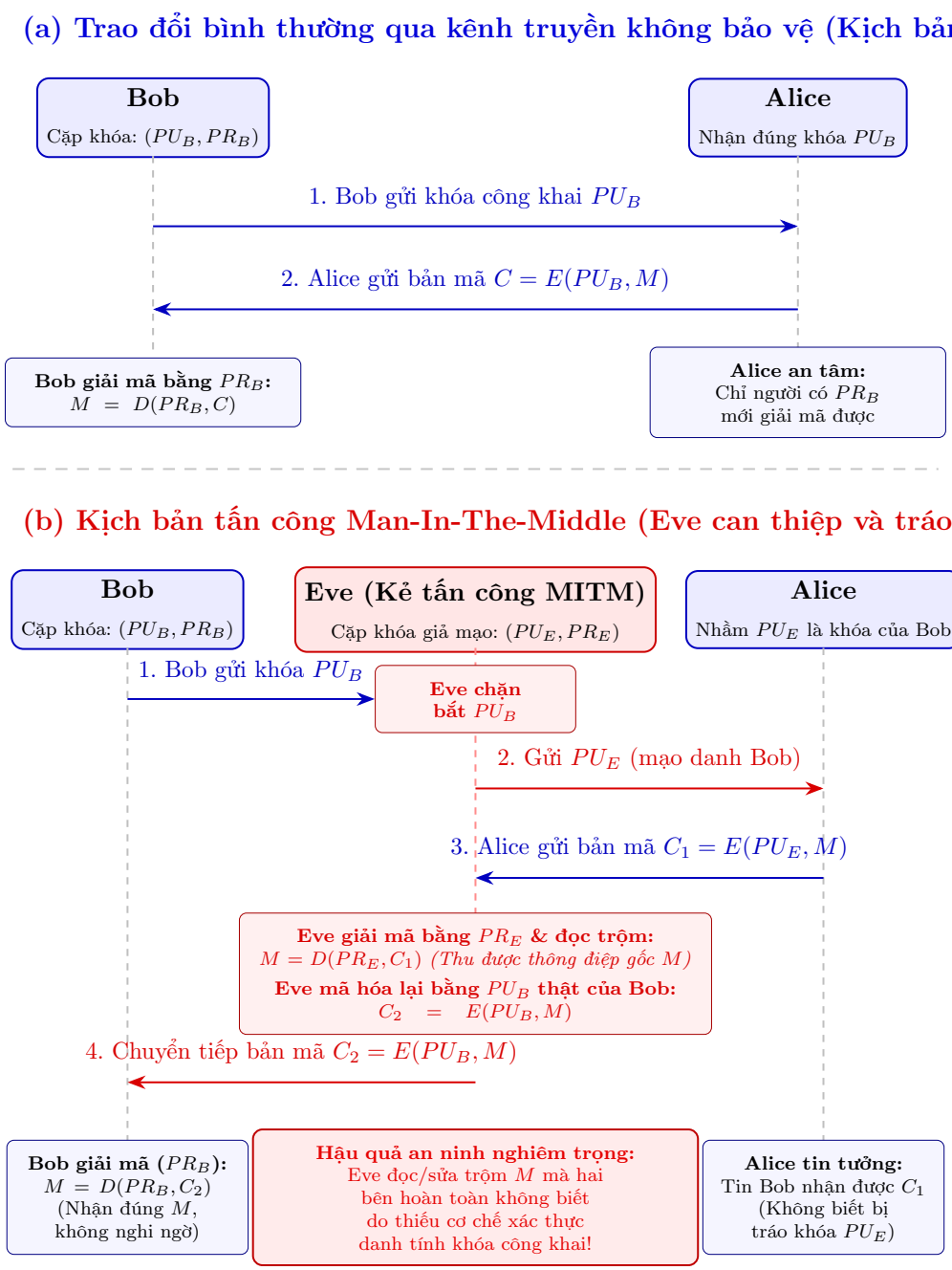
- $C_1 = E(PU_E, M)$ thể hiện bản mã tạo ra do Alice mã hóa bằng khóa công khai của kẻ tấn công Eve thay vì của Bob.
- $M = D(PR_E, C_1)$ chứng minh Eve có khả năng giải mã trực tiếp và thu thập nội dung thông tin mật nhờ nắm giữ khóa bí mật PR_E.
- $C_2 = E(PU_B, M)$ thể hiện việc Eve tái mã hóa thông điệp bằng khóa công khai hợp lệ của Bob để che đậy sự can thiệp của mình.

Cuộc tấn công người đứng giữa (MITM) này thành công vì Eve đã lợi dụng việc Alice hoàn toàn không có khả năng xác minh nguồn gốc và tính hợp lệ của khóa công khai nhận được. Mô hình trao đổi bình thường và cuộc tấn công thay thế khóa được minh họa tổng hợp tại Hình 1.1.

1.1.4 Phân tích bản chất bài toán và vai trò của PKI

Phân tích kịch bản tấn công của Eve làm bộc lộ những bài học cơ bản về an toàn mật mã:

- **Phân biệt tính bí mật của dữ liệu và tính xác thực của khóa công khai:** Mật mã hóa chỉ đảm bảo tính bí mật (confidentiality) của thông điệp đối với đối tượng sở hữu khóa bí mật tương ứng. Tuy nhiên, tính bí mật đó trở nên vô nghĩa nếu bản thân chiếc khóa công khai được dùng để mã hóa không bảo đảm tính xác thực (authenticity) và không có căn cứ xác thực nguồn gốc (origin authenticity).



Hình 1.1: Mô hình trao đổi thông tin thông thường và kịch bản tấn công thay thế khóa của Eve.

- **Nghịch lý toán học trong bảo mật hệ thống:** Các thuật toán mật mã cơ sở (như các hàm mã hóa phi đối xứng) vẫn hoạt động hoàn toàn chính xác theo đúng các định lý toán học (C_1 giải mã chính xác bằng PR_E, và C_2 giải mã chính xác bằng PR_B). Mặc dù thuật toán không hề bị bẻ gãy, hệ thống bảo mật tổng thể vẫn bị phá vỡ vì khóa đưa vào thuật toán không thuộc về đúng đối tượng dự kiến.

- **Các nguy cơ và hậu quả bảo mật:**

  - *Lộ lọt dữ liệu bí mật:* Kẻ tấn công có thể đọc trộm toàn bộ thông điệp trao đổi giữa các bên.
  - *Giả mạo danh tính (Impersonation):* Kẻ tấn công có thể thay phiên đóng vai cả hai bên đối thoại một cách trót lọt.
  - *Sửa đổi và thao túng thông điệp (Tampering):* Eve không chỉ dừng lại ở việc đọc trộm mà còn có thể can thiệp, sửa đổi nội dung M thành M' trước khi mã hóa lại thành $C_2 = E(PU_B, M')$, gây sai lệch hoàn toàn dữ liệu nếu giao thức không có cơ chế bảo vệ tính toàn vẹn và chữ ký số thích hợp.

Do đó, thách thức cốt lõi đặt ra là: **Phải có một cơ chế đáng tin cậy để liên kết (bind) một khóa công khai cụ thể với danh tính thực tế của chủ sở hữu hợp pháp**.

Để thiết lập mối liên kết đáng tin cậy giữa danh tính và khóa công khai mà không đòi hỏi các bên phải gặp mặt trực tiếp hoặc thiết lập kênh bí mật trước, **Hạ tầng khóa công khai (Public Key Infrastructure - PKI)** đã được chuẩn hóa và triển khai như một giải pháp nền tảng. PKI là một hệ thống hạ tầng toàn diện bao gồm phần cứng, phần mềm, chính sách và tiêu chuẩn hỗ trợ quản lý, phân phối, lưu trữ và xác thực mối liên hệ giữa khóa công khai với danh tính của các thực thể thông qua các cấu phần và cơ chế then chốt:

- **Tổ chức chứng thực số (Certificate Authority - CA):** Là bên thứ ba đáng tin cậy (Trusted Third Party). CA có trách nhiệm thẩm tra tính chính xác về danh tính của đối tượng yêu cầu trước khi cấp phát chứng thư số.

- **Chứng thư số (Digital Certificate):** Là cấu trúc dữ liệu điện tử (thường theo chuẩn quốc tế ITU-T X.509) đóng gói khóa công khai cùng với các thông tin định danh của chủ thể (Subject) sở hữu khóa đó.

- **Chữ ký số (Digital Signature):** CA sử dụng khóa bí mật của chính mình để tạo chữ ký số trên toàn bộ nội dung của chứng thư, bảo đảm tính toàn vẹn và chống chối bỏ cho mối liên kết giữa danh tính và khóa công khai.

Trong môi trường có sự hỗ trợ của PKI, khi Alice muốn liên lạc với Bob, thay vì nhận một khóa công khai trần dễ bị đánh tráo, Alice sẽ nhận được một chứng thư số của Bob do một CA đáng tin cậy ban hành. Alice có thể thực hiện quy trình kiểm tra toàn diện:

1. **Kiểm tra chữ ký của CA:** Alice sử dụng khóa công khai của CA (vốn đã được cài đặt sẵn và tin cậy trước trong hệ thống) để xác thực chữ ký số trên chứng thư của Bob.

2. **Xác minh danh tính chủ thể:** Alice kiểm tra xem thông tin định danh (như tên chủ thể, tên miền) có khớp chính xác với Bob hay không.

3. **Kiểm tra thời hạn hiệu lực:** Alice đối chiếu thời điểm hiện tại với khoảng thời gian hợp lệ được quy định trên chứng thư (các trường `notBefore` và `notAfter`).

4. **Kiểm tra trạng thái thu hồi:** Alice kiểm tra xem chứng thư có bị thu hồi trước thời hạn (ví dụ do lộ khóa bí mật) hay không thông qua danh sách thu hồi chứng thư (CRL) hoặc giao thức trạng thái chứng thư trực tuyến (OCSP) theo các chính sách áp dụng.

Giới hạn của PKI và sự cố thực tế kinh điển (DigiNotar 2011): Cần khẳng định rằng, PKI không phải là một giải pháp loại bỏ hoàn toàn mọi nguy cơ an ninh. PKI về thực chất là một hạ tầng quản trị niềm tin (*trust management*); an ninh của hệ thống bị ràng buộc chặt chẽ bởi các chính sách vận hành và tính toàn vẹn của các CA gốc (Trust Anchors). Nếu một CA bị xâm nhập hoặc cấp sai chứng thư, toàn bộ chuỗi tin cậy sẽ bị lợi dụng để hợp thức hóa các hành vi tấn công mà trình duyệt máy trạm khó có thể tự phát hiện bằng các kiểm tra toán học thông thường.

Minh chứng điển hình cho giới hạn này là **sự cố DigiNotar (2011)** [1], khi một CA công cộng của Hà Lan bị tin tặc chiếm quyền và phát hành hàng loạt chứng thư giả mạo (*rogue certificates*) có chữ ký mật mã hoàn toàn hợp lệ cho tên miền `*.google.com`. Kẻ tấn công đã sử dụng các chứng thư này để triển khai tấn công người đứng giữa (MITM) đối với hàng trăm nghìn người dùng Internet mà không hề làm phát sinh cảnh báo lỗi chứng thư, buộc các hãng công nghệ lớn phải xóa bỏ hoàn toàn DigiNotar khỏi Root Trust Store. Sự cố khẳng định một nguyên lý cốt lõi: chữ ký mật mã đúng là điều kiện cần nhưng chưa đủ để bảo đảm an toàn nếu niềm tin vào CA bị vi phạm (phân tích chi tiết về vectơ tấn công và bài học kiến trúc từ sự cố này sẽ được mổ xẻ tại Mục 5.1 ở Chương 5).

Chính vì vậy, bài toán nghiên cứu trọng tâm được xác định là: **Làm thế nào để phân phối và xác thực khóa công khai một cách đáng tin cậy, hạn chế tối đa nguy cơ giả mạo và tấn công thay thế khóa, đồng thời đánh giá được các điều kiện chấp nhận và giới hạn an ninh của hệ thống trong thực tế triển khai?** Đây là động lực thúc đẩy các mục tiêu và câu hỏi nghiên cứu cụ thể trong đề tài này.

1.2 Mục tiêu và câu hỏi nghiên cứu

Mục tiêu của đề tài là phân tích kiến trúc hạ tầng khóa công khai (PKI), tìm hiểu cơ chế xác thực chứng thư số theo tiêu chuẩn X.509 và xây dựng một môi trường thực nghiệm (lab) nhằm kiểm chứng các điều kiện chấp nhận hoặc từ chối chứng thư. Thông qua đó, đề tài làm rõ cách PKI thiết lập mối liên hệ tin cậy giữa danh tính và khóa công khai, đồng thời đánh giá vai trò của cơ chế thu hồi chứng thư trong việc bảo đảm an toàn thông tin.

Để đạt được mục tiêu trên, đề tài tập trung giải quyết các câu hỏi nghiên cứu sau:

1. **RQ1:** PKI liên kết danh tính với khóa công khai bằng cách nào?

2. **RQ2:** Những điều kiện nào khiến chứng thư X.509 được chấp nhận hoặc từ chối?

3. **RQ3:** CRL và OCSP giúp giảm thiểu rủi ro liên quan đến chứng thư bị thu hồi như thế nào?

4. **RQ4:** Những điểm yếu nào vẫn tồn tại trong PKI ngay cả khi các thuật toán mật mã được sử dụng vẫn bảo đảm an toàn?

Trong đó, mối liên hệ giữa các câu hỏi nghiên cứu với cấu trúc các chương trong báo cáo được phân bổ cụ thể:

- **RQ1** được làm sáng tỏ qua phân tích lý thuyết về kiến trúc PKI, mô hình tin cậy và cấu trúc chứng thư X.509 ở Chương 3 và Chương 4;
- **RQ2** và **RQ3** được đối chiếu giữa lý thuyết thuật toán xác thực đường dẫn, cơ chế thu hồi (Chương 4) và kiểm chứng trực quan bằng thực nghiệm 10 ca kiểm thử chuyên sâu (TC01–TC10) ở Chương 6;
- **RQ4** được mổ xẻ chuyên sâu qua mô hình hóa rủi ro, phân tích giới hạn của chữ ký hợp lệ tại Chương 5 và các hướng tiếp cận nâng cao (như Certificate Transparency, tự động hóa ACME) ở Chương 7.

Thông qua việc trả lời các câu hỏi nghiên cứu và kiểm chứng bằng thực nghiệm, đề tài hướng đến việc làm rõ các yếu tố quyết định độ tin cậy của PKI, nhận diện những hạn chế trong quá trình xác thực và quản lý chứng thư số, từ đó nâng cao hiểu biết về khả năng ứng dụng cũng như các rủi ro an toàn thông tin của hệ thống PKI trong thực tế.

1.3 Phạm vi và phương pháp nghiên cứu

- **Phạm vi nghiên cứu:** Đề tài tập trung nghiên cứu mô hình PKI phân cấp chuẩn ITU-T X.509 v3 và cơ chế xác thực máy chủ (Server Authentication) trong giao thức TLS trên môi trường phòng thí nghiệm nội bộ (lab). Trọng tâm nghiên cứu bao gồm cấu trúc các trường chứng thư và phần mở rộng quan trọng (SAN, Basic Constraints, Key Usage), thuật toán xác minh chuỗi tin cậy, hai cơ chế kiểm tra thu hồi (CRL và OCSP), cùng các mô hình đe dọa và hạn chế an ninh cố hữu của PKI.
- **Phương pháp nghiên cứu:** Đề tài kết hợp phương pháp nghiên cứu tài liệu chuẩn hóa quốc tế (RFC 5280, RFC 6960, RFC 8446, RFC 3647) với phương pháp thực nghiệm khoa học. Nhóm nghiên cứu thiết kế và triển khai một hạ tầng PKI hoàn chỉnh bằng công cụ OpenSSL, xây dựng chuỗi chứng thư nhiều cấp và thực thi 10 ca kiểm thử độc lập (TC01–TC10) nhằm ghi nhận, đo lường và đối chiếu trực quan hành vi thẩm định chứng thư thực tế với các ràng buộc lý thuyết.

1.4 Cấu trúc của báo cáo

Báo cáo nghiên cứu được bố cục thành 7 chương chuyên môn và phần kết luận, cụ thể như sau:

- **Chương 1 – Giới thiệu và xác định vấn đề nghiên cứu:** Trình bày bối cảnh ra đời của mật mã khóa công khai, phân tích lỗ hổng cố hữu trong phân phối khóa trần qua kịch bản tấn công người đứng giữa (MITM), sự cần thiết của PKI, mục tiêu, 4 câu hỏi nghiên cứu (RQ1–RQ4), phạm vi triển khai và phương pháp luận của đề tài.

- **Chương 2 – Cơ sở mật mã khóa công khai và PKI:** Trình bày cơ sở lý thuyết mật mã bất đối xứng, hàm băm mật mã, chữ ký số, quản lý vòng đời khóa và vai trò của các lớp thuật toán trong giao thức TLS 1.3.

- **Chương 3 – Kiến trúc PKI và vòng đời chứng thư:** Phân tích kiến trúc tổng thể của PKI, các thành phần và mô hình tin cậy, quy trình quản lý vòng đời chứng thư và chính sách vận hành (CP/CPS) theo khung RFC 3647.

- **Chương 4 – X.509, chuỗi tin cậy và cơ chế xác thực:** Đi sâu vào cấu trúc chứng thư số chuẩn ITU-T X.509 v3, thuật toán xây dựng và thẩm định đường dẫn chứng thư, cùng cơ chế kiểm tra trạng thái thu hồi (CRL và OCSP).

- **Chương 5 – Phân tích bảo mật, mô hình tấn công và so sánh:** Mô hình hóa đe dọa, so sánh đối chiếu các mô hình tin cậy (PKI, Web of Trust, TOFU), và phân tích giới hạn của chữ ký hợp lệ thông qua nghiên cứu điển hình về sự cố DigiNotar (2011).

- **Chương 6 – Thiết kế và đánh giá thực nghiệm:** Thiết kế môi trường lab OpenSSL, kết quả thực nghiệm 10 ca kiểm thử (TC01–TC10) và các thảo luận, đánh giá chuyên sâu.

- **Chương 7 – Ứng dụng và hướng phát triển PKI:** Khảo sát các ứng dụng thực tế của PKI, cơ chế minh bạch chứng thư (Certificate Transparency - CT), tự động hóa quản lý chứng thư qua giao thức ACME và định hướng chuyển đổi sang mật mã hậu lượng tử (PQC).

- **Kết luận và hướng phát triển:** Tổng kết các phát hiện chính, đối chiếu và giải đáp 4 câu hỏi nghiên cứu, chỉ rõ các giới hạn của mô hình thực nghiệm và đề xuất hướng nghiên cứu mở rộng trong tương lai.

Chương 2

Cơ sở mật mã khóa công khai và PKI

2.1 Yêu cầu bảo mật và quản lý khóa

2.1.1 Yêu cầu bảo mật trong truyền thông và vai trò của PKI

Trong an toàn thông tin hiện đại, việc bảo vệ luồng truyền thông và dữ liệu giao dịch xoay quanh mô hình các mục tiêu an ninh cơ bản (mô hình CIA mở rộng):

- **Tính bí mật (Confidentiality):** Đảm bảo thông tin chỉ được truy cập và đọc hiểu bởi các đối tượng có thẩm quyền (sở hữu khóa giải mã hợp lệ), ngăn chặn hành vi nghe lén hoặc giải mã trái phép từ bên thứ ba trên kênh truyền thông công cộng.
- **Tính toàn vẹn (Integrity):** Đảm bảo dữ liệu không bị sửa đổi, chèn thêm, xóa bớt hoặc tái sắp xếp trái phép trong quá trình lưu trữ và truyền tải. Mọi biến đổi dù là nhỏ nhất trên thông điệp đều phải được phát hiện kịp thời.
- **Tính xác thực (Authenticity):** Đảm bảo nguồn gốc của dữ liệu và định danh thực tế của thực thể tham gia giao tiếp là chính xác và có thể kiểm chứng được, ngăn ngừa hành vi giả mạo danh tính (*impersonation*) hoặc tấn công người đứng giữa (MITM).
- **Tính sẵn sàng (Availability):** Đảm bảo hệ thống, tài nguyên và dịch vụ xác thực luôn sẵn sàng phục vụ các bên tin cậy khi có yêu cầu hợp lệ, không bị gián đoạn bởi sự cố kỹ thuật hoặc các cuộc tấn công từ chối dịch vụ (DoS/DDoS).
- **Tính chống chối bỏ (Non-repudiation):** Đảm bảo thực thể đã thực hiện một hành động (như ký duyệt văn bản hay phát hành chứng thư) không thể phủ nhận hành vi của mình đối với bên thứ ba độc lập.

Hạ tầng khóa công khai (PKI) về bản chất là một cơ chế quản trị niềm tin và định danh số. Do đó, PKI không trực tiếp giải quyết toàn bộ các mục tiêu an ninh nói trên mà có sự phân định rõ ràng giữa thuộc tính hỗ trợ trực tiếp và thuộc tính cần phối hợp với các cơ chế bảo mật khác:

- **Các thuộc tính PKI hỗ trợ trực tiếp:**
  - *Tính xác thực (Authenticity):* Đây là mục tiêu cốt lõi của PKI. Thông qua chứng thư số chuẩn ITU-T X.509 và chữ ký số của Tổ chức chứng thực (CA),

PKI liên kết chặt chẽ danh tính thực tế của chủ thể (Subject) với khóa công khai tương ứng, loại bỏ triệt để nguy cơ phân phối khóa công khai trần không rõ nguồn gốc.

  - *Tính toàn vẹn (Integrity) và Chống chối bỏ (Non-repudiation):* Bằng việc đóng gói dữ liệu và ký số bằng khóa bí mật của CA hoặc của chủ thể, PKI bảo đảm tính toàn vẹn của chứng thư số và thông điệp giao dịch; đồng thời ngăn chặn bên ký chối bỏ trách nhiệm về dữ liệu đã ban hành.

- **Các thuộc tính cần kết hợp cơ chế bảo vệ khác:**

  - *Tính bí mật (Confidentiality):* Bản thân PKI và chứng thư X.509 không trực tiếp thực hiện việc mã hóa dữ liệu ứng dụng. Khóa công khai trong chứng thư chủ yếu phục vụ xác thực danh tính và thỏa thuận khóa; việc bảo vệ bí mật cho luồng dữ liệu đòi hỏi các giao thức truyền thông an toàn (như TLS 1.3 [2]) sử dụng cơ chế trao đổi khóa phiên (như ECDHE) kết hợp thuật toán mã hóa đối xứng khối lượng lớn (như AES-GCM hoặc ChaCha20-Poly1305).
  - *Tính sẵn sàng (Availability):* Dù PKI định nghĩa các dịch vụ kiểm tra trạng thái chứng thư (CRL, OCSP), tính sẵn sàng của hạ tầng phụ thuộc hoàn toàn vào kiến trúc mạng và giải pháp phân phối (như cân bằng tải, cơ chế lưu đệm OCSP Stapling, mạng phân phối nội dung CDN) nhằm tránh nghẽn cổ chai và ngăn ngừa tấn công làm tê liệt điểm kiểm tra thu hồi.

Bảng 2.1 tóm tắt phạm vi hỗ trợ của PKI đối với các mục tiêu an ninh thông tin.

Mục tiêu an ninh	**Vai trò của PKI**	**Cơ chế thực hiện / Phối hợp**
Xác thực (Authenticity)	Hỗ trợ trực tiếp	Chứng thư số X.509, chữ ký số của CA trên Subject PublicKey.
Toàn vẹn (Integrity)	Hỗ trợ trực tiếp	Hàm băm mật mã và chữ ký số trên cấu trúc chứng thư.
Chống chối bỏ (Non-repudiation)	Hỗ trợ trực tiếp	Chữ ký số gắn liền với khóa bí mật duy nhất của thực thể.
Bí mật (Confidentiality)	Kết hợp bên ngoài	Giao thức TLS bắt tay thỏa thuận khóa phiên (ECDHE) và mã hóa đối xứng (AES-GCM).
Sẵn sàng (Availability)	Kết hợp bên ngoài	Hạ tầng mạng phân tán, bộ đệm chứng thực, OCSP Stapling, CDN.

Bảng 2.1: Phân định phạm vi hỗ trợ của PKI đối với các mục tiêu an ninh thông tin.

2.1.2 Nguyên lý quản lý khóa và vòng đời khóa mật mã

Theo *Nguyên lý Kerckhoffs*, độ an toàn của một hệ thống mật mã không phụ thuộc vào việc giữ bí mật thuật toán mà nằm hoàn toàn ở sự an toàn của khóa mật mã. Trong

hệ thống khóa bất đối xứng, hai thành phần của cặp khóa có yêu cầu bảo vệ trái ngược nhau:

- **Khóa công khai (Public Key):** Đòi hỏi tính *toàn vẹn* và tính *xác thực* nguồn gốc tuyệt đối (đây chính là nhiệm vụ của chứng thư số PKI), nhưng không cần giữ bí mật.
- **Khóa bí mật (Private Key):** Đòi hỏi tính *bí mật* và *bảo vệ quyền truy cập* tuyệt đối. Nếu khóa bí mật bị lộ, toàn bộ các bảo đảm an ninh về xác thực và chống chối bỏ đều sụp đổ.

Quản lý khóa (Key Management) là tập hợp toàn bộ các chính sách và kỹ thuật nhằm kiểm soát cặp khóa xuyên suốt vòng đời (Key Lifecycle):

1. **Khởi tạo khóa (Generation):** Phải sử dụng bộ sinh số ngẫu nhiên giả an toàn mật mã (CSPRNG) và tuân thủ độ dài khóa khuyến nghị (ví dụ RSA $\geq$ 2048-bit, ECC $\geq$ 256-bit) để chống thám mã vét cạn.
2. **Lưu trữ và bảo vệ khóa bí mật (Storage):** Khóa bí mật của các CA gốc và máy chủ quan trọng phải được lưu trữ trong các mô-đun phần cứng chuyên dụng (Hardware Security Module - HSM hoặc TPM) với chính sách kiểm soát truy cập nghiêm ngặt (quản trị phân quyền k-out-of-n). Khóa tuyệt đối không được xuất ra ngoài bộ nhớ dưới dạng bản rõ.
3. **Phân phối và chứng thực (Distribution):** Khóa công khai được đóng gói thành yêu cầu cấp chứng thư (CSR) và gửi tới CA để thẩm định, cấp phát chứng thư X.509.
4. **Thời hạn sử dụng (Cryptoperiod):** Mọi khóa mật mã đều phải có thời hạn hiệu lực hữu hạn (`notBefore` và `notAfter`) để hạn chế lượng bản mã tích lũy cho đối thủ phân tích, đồng thời bắt buộc chu kỳ thay thế khóa định kỳ.
5. **Thu hồi và tiêu hủy (Revocation & Destruction):** Khi khóa bí mật nghi ngờ bị lộ, chủ sở hữu phải lập tức yêu cầu CA đưa chứng thư vào danh sách thu hồi (CRL/OCSP). Khi hết vòng đời, khóa bí mật phải bị xóa hủy an toàn (zeroize) để ngăn ngừa phục hồi dữ liệu từ phần cứng.

2.2 Khóa công khai, hàm băm và chữ ký số

Để phân tích chính xác cơ chế hoạt động của hạ tầng PKI, cần phân định rành mạch giữa các nguyên hàm mật mã cơ sở gồm cặp khóa bất đối xứng, hàm băm một chiều, chữ ký số và chứng thư số:

- **Cặp khóa công khai và khóa bí mật (PK, SK):** Trong mật mã bất đối xứng, mỗi thực thể sở hữu một cặp khóa có quan hệ toán học chặt chẽ. Khóa công khai (PK) được phổ biến rộng rãi cho toàn bộ mạng lưới, trong khi khóa bí mật (SK) phải được lưu trữ và bảo vệ tuyệt đối bởi chủ sở hữu. Tuy nhiên, bản thân cặp khóa chỉ tồn tại dưới dạng các giá trị nhị phân trừu tượng; nó hoàn toàn không chứa thông tin định danh và không tự chứng minh được danh tính thực tế của chủ thể nắm giữ khóa.

- **Hàm băm mật mã (H):** Là hàm toán học một chiều ánh xạ một thông điệp m có kích thước tùy ý thành một chuỗi bit có độ dài cố định gọi là giá trị tóm lược (digest): $h = H(m)$. Hàm băm mật mã chuẩn bắt buộc phải thỏa mãn ba tính chất: kháng tiền ảnh (pre-image resistance), kháng tiền ảnh thứ hai (second pre-image resistance) và kháng va chạm (collision resistance). Mặc dù hàm băm đảm bảo phát hiện mọi sửa đổi dữ liệu (tính toàn vẹn), nó không thể xác thực nguồn gốc thông điệp vì không chứa yếu tố bí mật.

- **Chữ ký số (Digital Signature):** Là sự kết hợp giữa hàm băm và mật mã khóa công khai nhằm bảo đảm tính toàn vẹn, xác thực nguồn gốc và chống chối bỏ. Về mặt mô hình khái niệm, chữ ký số được định nghĩa thông qua cặp thuật toán:

$$\sigma = \text{Sign}(SK, H(m)) \tag{2.1}$$

$$\text{Verify}(PK, H(m), \sigma) \in \{\text{True}, \text{False}\} \tag{2.2}$$

  Cần lưu ý rằng các biểu thức trên chỉ đại diện cho mô hình khái niệm trừu tượng. Trong thực tế triển khai, thao tác tính toán phụ thuộc chặt chẽ vào cấu trúc toán học của từng lược đồ chữ ký và các cơ chế đệm (padding) chuẩn hóa:

  - *RSA (PKCS#1 v1.5 / RSA-PSS):* Dữ liệu băm được đệm theo sơ đồ xác suất PSS để ngăn chặn tấn công đại số trước khi áp dụng phép lũy thừa modulo: $\sigma = (H_{pad}(m))^d \pmod N$.
  - *ECDSA (Elliptic Curve Digital Signature Algorithm):* Thực hiện trên nhóm điểm của đường cong elip, yêu cầu sinh một giá trị ngẫu nhiên bí mật k trên mỗi phiên ký để tạo cặp giá trị chữ ký (r, s).
  - *Ed25519 (EdDSA):* Sử dụng đường cong xoắn Edwards với cơ chế sinh tham số ngẫu nhiên mang tính tất định dẫn xuất từ khóa bí mật và thông điệp, triệt tiêu rủi ro lộ khóa do bộ sinh số ngẫu nhiên kém an toàn.

- **Chứng thư số (Digital Certificate):** Chữ ký số chứng minh được một thông điệp được tạo ra bởi người sở hữu khóa SK, nhưng không thể trả lời câu hỏi thực thể đó là ai ngoài đời thực. Chứng thư số chuẩn ITU-T X.509 đóng vai trò đóng gói khóa công khai PK cùng định danh của chủ thể (Subject) và được một bên thứ ba tin cậy (Certificate Authority - CA) xác thực bằng chữ ký số sử dụng khóa bí mật SK_{CA}. Bằng cách này, chứng thư số hoàn thiện mắt xích liên kết tin cậy (binding) giữa danh tính và khóa công khai.

Bản chất kỹ thuật và giới hạn của các thành phần mật mã được tổng hợp và đối chiếu tại Bảng 2.2.

Bảng 2.2: So sánh bản chất và vai trò của các thành phần mật mã trong PKI

Khái niệm	**Bản chất kỹ thuật**	**Khóa bí mật (SK)**	**Giá trị an ninh cung cấp**	**Hạn chế nội tại**
Cặp khóa (PK, SK)	Hai khóa có liên hệ toán học; PK công khai, SK bảo mật.	Chỉ duy nhất chủ sở hữu hợp pháp nắm giữ và bảo vệ.	Nền tảng cho ký số, xác thực sở hữu và thỏa thuận khóa phiên.	Không tự liên kết được với danh tính thực thể ngoài đời thực.
Hàm băm (H)	Ánh xạ thông điệp tùy ý thành digest có độ dài cố định.	Không sử dụng khóa.	Bảo đảm tính toàn vẹn, tóm lược dữ liệu, kháng va chạm.	Không xác thực nguồn gốc do bất kỳ ai cũng tính toán được.
Chữ ký số	Cặp thuật toán Sign/Verify thao tác trên giá trị băm thông điệp.	Ký bằng SK của chủ thể; kiểm tra bằng PK tương ứng.	Xác thực nguồn gốc dữ liệu, bảo đảm tính toàn vẹn và chống chối bỏ.	Chỉ xác minh tính hợp lệ của dữ liệu với PK, không định danh người ký.
Chứng thư số	Cấu trúc dữ liệu liên kết PK với danh tính, được CA ký.	Ký bởi SK_{CA}; cấu trúc chứng thư không bao giờ chứa SK.	Thiết lập liên kết tin cậy giữa khóa công khai và danh tính chủ thể.	Phụ thuộc độ tin cậy của CA, thời hạn hiệu lực và trạng thái thu hồi.

2.3 Vai trò thuật toán trong TLS

Một trong những sai lầm phổ biến khi tiếp cận mật mã học là quan niệm cho rằng khóa công khai trong chứng thư số X.509 được sử dụng để mã hóa trực tiếp toàn bộ dữ liệu ứng dụng trao đổi trên kênh truyền mạng. Trong các hệ thống bảo mật hiện đại như giao thức Transport Layer Security phiên bản 1.3 (TLS 1.3, chuẩn hóa tại RFC 8446 [2]), các thuật toán mật mã được phân công trách nhiệm độc lập theo từng lớp chức năng riêng biệt nhằm tối ưu hóa hiệu năng tính toán và bảo đảm an toàn tối đa:

- **Xác thực danh tính (Authentication Layer):**
  - *Bản chất:* Chứng thư số của máy chủ chứa khóa công khai dài hạn (PK_{server}) và được chứng thực thông qua chữ ký số của một CA tin cậy (SK_{CA}) nhằm giải quyết bài toán liên kết định danh.
  - *Cơ chế trong TLS 1.3:* Trong giai đoạn bắt tay (Handshake), máy chủ gửi chứng thư X.509 cho client và phát hành thông điệp xác thực `CertificateVerify`. Thông điệp này được ký bằng khóa bí mật dài hạn (SK_{server}) lên toàn bộ bản ghi lịch sử (*transcript*) của các gói tin bắt tay trước đó.
  - *Mục tiêu:* Sử dụng các thuật toán chữ ký số hiện đại (như RSA-PSS, ECDSA với đường cong secp256r1/secp384r1, hoặc Ed25519) nhằm chứng minh máy chủ thực sự sở hữu khóa bí mật tương ứng với chứng thư (*Proof of Possession*), loại bỏ hoàn toàn nguy cơ giả mạo danh tính (impersonation). Khóa công khai này tuyệt đối không dùng để mã hóa lưu lượng dữ liệu.
- **Thỏa thuận khóa phiên (Key Exchange / Agreement Layer):**
  - *Bản chất:* Nhằm thiết lập một khóa bí mật chung giữa client và server qua kênh truyền không tin cậy mà không bao giờ truyền trực tiếp khóa đó trên mạng.
  - *Cơ chế trong TLS 1.3:* Khác biệt căn bản với các phiên bản TLS cũ (vốn cho phép dùng khóa RSA của chứng thư để mã hóa và gửi khóa tiền phiên *pre-master secret*), TLS 1.3 đã loại bỏ hoàn toàn cơ chế trao đổi khóa RSA tĩnh. Thay vào đó, giao thức bắt buộc sử dụng cơ chế trao đổi khóa tạm thời dựa trên Diffie-Hellman: ECDHE (*Ephemeral Elliptic Curve Diffie-Hellman*, như X25519) hoặc DHE.
  - *Đặc tính Bí mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy - PFS):* Cặp khóa bất đối xứng tạm thời (*ephemeral key pair*) được sinh ngẫu nhiên độc lập cho từng phiên kết nối và bị hủy ngay sau khi bắt tay. Do đó, ngay cả khi khóa bí mật dài hạn của máy chủ bị xâm phạm trong tương lai, kẻ tấn công cũng không thể giải mã hồi cứu các phiên truyền thông đã lưu vết trong quá khứ.
- **Mã hóa đối xứng dữ liệu ứng dụng (Record Layer Encryption):**
  - *Bản chất:* Dữ liệu trao đổi thực tế (HTTP requests/responses, JSON, hình ảnh) có dung lượng rất lớn. Việc dùng mật mã khóa công khai để mã hóa từng gói tin sẽ làm tê liệt hạ tầng mạng do chi phí tính toán modulo và đường cong elip cực kỳ đắt đỏ.

– *Cơ chế trong TLS 1.3:* Giá trị bí mật chung sau ECDHE được đưa qua hàm suy dẫn khóa HKDF (*HMAC-based Extract-and-Expand Key Derivation Function*) để sinh ra các khóa phiên đối xứng. Tầng Record sau đó sử dụng độc quyền các thuật toán mã hóa đối xứng có xác thực: AEAD (*Authenticated Encryption with Associated Data*), tiêu biểu như AES-128-GCM, AES-256-GCM hoặc ChaCha20-Poly1305.

– *Mục tiêu:* Bảo đảm đồng thời tính bí mật (Confidentiality) và tính toàn vẹn (Integrity) cho từng bản ghi dữ liệu ứng dụng với tốc độ xử lý phần cứng cao (tận dụng tập lệnh AES-NI) và độ trễ thấp nhất.

Sự phân định vai trò và phối hợp giữa các thành phần thuật toán trong TLS 1.3 được tổng hợp tại Bảng 2.3.

Bảng 2.3: Phân định vai trò các thuật toán mật mã trong giao thức TLS 1.3

Lớp chức năng	**Thuật toán tiêu biểu**	**Khóa mật mã sử dụng**	**Mục tiêu an ninh đáp ứng**
Xác thực (Authentication)	RSA-PSS, ECDSA (secp256r1), Ed25519.	Khóa bất đối xứng dài hạn (PK, SK) trong chứng thư X.509.	Xác thực nguồn gốc máy chủ, ngăn chặn tấn công mạo danh và người đứng giữa (MITM).
Thỏa thuận khóa (Key Exchange)	ECDHE (X25519, secp256r1), DHE.	Cặp khóa bất đối xứng tạm thời (ephemeral), sinh mới mỗi phiên.	Thiết lập bí mật chung an toàn; bảo đảm Bí mật chuyển tiếp hoàn hảo (PFS).
Mã hóa dữ liệu (Record Layer)	AEAD (AES-128-GCM, AES-256-GCM, ChaCha20-Poly1305).	Khóa đối xứng phiên (Session Key) suy dẫn qua HKDF.	Bảo đảm tính bí mật và toàn vẹn dữ liệu ứng dụng với tốc độ và hiệu năng tối ưu.

Trong phạm vi của đề tài nghiên cứu này, các nội dung tiếp theo (Chương 3, Chương 4 và kết quả thực nghiệm tại Chương 6) sẽ tập trung làm rõ lớp chức năng đầu tiên: cấu trúc chứng thư X.509, quy trình thẩm định chuỗi tin cậy và cơ chế thu hồi của hạ tầng PKI.

Chương 3

Kiến trúc PKI và vòng đời chứng thư

3.1 Thành phần và mô hình tin cậy

Hạ tầng khóa công khai (Public Key Infrastructure – PKI) là một hệ thống tích hợp toàn diện bao gồm phần cứng, phần mềm, quy trình, nhân sự và các chính sách quản lý nhằm tạo lập, lưu trữ, phân phối và thu hồi chứng thư số theo chuẩn ITU-T X.509. Về bản chất, PKI giải quyết bài toán niềm tin phân tán trên môi trường mạng mở bằng cách chuyển dịch việc tin cậy lẫn nhau giữa các đối tượng ngang hàng (vốn đòi hỏi $O(n^2)$ mối quan hệ bảo mật trực tiếp) sang việc cùng đặt niềm tin vào một bên thứ ba có thẩm quyền và uy tín (Trusted Third Party).

3.1.1 Các thành phần cốt lõi trong PKI

Một hệ thống PKI hoàn chỉnh bao gồm các cấu phần chức năng phối hợp chặt chẽ với nhau trong việc quản lý và duy trì chuỗi tin cậy:

- **Gốc tin cậy (Trust Anchor):** Là điểm khởi đầu tuyệt đối của niềm tin mà bên tin cậy (Relying Party) chấp nhận trước một cách vô điều kiện mà không cần bất kỳ chữ ký của bên thứ ba nào xác nhận thêm. Trong thực tế triển khai, Trust Anchor thường là khóa công khai của một Root CA được lưu trữ trực tiếp, an toàn trong kho chứng thư tin cậy (Trust Store) của hệ điều hành (như Windows, Linux, macOS) hoặc trình duyệt web độc lập (như Mozilla Firefox).
- **Tổ chức chứng thực gốc (Root CA – Root Certificate Authority):** Là thực thể đứng ở đỉnh cao nhất của mô hình PKI phân cấp. Root CA sở hữu cặp khóa mã hóa tối cao và tự phát hành một chứng thư tự ký (Self-signed Certificate), trong đó trường định danh người phát hành (Issuer) trùng khớp hoàn toàn với trường định danh chủ thể (Subject). Khóa bí mật của Root CA (SK_{Root}) là tài sản tối mật, luôn được lưu giữ ở trạng thái ngoại tuyến (offline) tuyệt đối trong các mô-đun phần cứng an toàn chuyên dụng (Hardware Security Module – HSM) nhằm triệt tiêu nguy cơ bị xâm nhập qua mạng. Root CA chỉ được đưa vào vận hành theo quy trình kiểm toán nghiêm ngặt khi cần ký cấp phát hoặc thu hồi chứng thư cho các Intermediate CA.
- **Tổ chức chứng thực trung gian (Intermediate CA / Sub-CA):** Là các CA được Root CA (hoặc một Intermediate CA cấp cao hơn) ủy quyền và cấp chứng thư

để thực hiện việc vận hành hàng ngày. Intermediate CA chịu trách nhiệm trực tiếp ký phát hành chứng thư cho các thực thể cuối (End-entity) và phát hành danh sách thu hồi (CRL). Việc thiết lập mô hình phân tầng qua Intermediate CA tạo ra một lớp bảo vệ và cô lập rủi ro (isolation layer): nếu một Intermediate CA bị thỏa hiệp hoặc lộ khóa, hệ thống chỉ cần thu hồi chứng thư của riêng Sub-CA đó mà không làm sụp đổ toàn bộ cây tin cậy của Root CA.

- **Cơ quan đăng ký (Registration Authority – RA):** Đóng vai trò là giao diện trung gian kết nối giữa người dùng/chủ thể và CA. RA có nhiệm vụ tiếp nhận yêu cầu cấp chứng thư (CSR), thực hiện quy trình thẩm tra tính xác thực về mặt định danh, tư cách pháp nhân hoặc quyền sở hữu tên miền của đối tượng yêu cầu trước khi chuyển yêu cầu đã được phê duyệt sang cho CA ký phát hành. Bản thân RA không trực tiếp ký chứng thư và không được phép nắm giữ khóa bí mật của CA.

- **Chủ thể (Subject / End-entity):** Là các cá nhân, tổ chức, máy chủ dịch vụ (Web Server, Mail Server) hoặc thiết bị IoT sở hữu cặp khóa mật mã và được định danh trên chứng thư số. Chủ thể có trách nhiệm lưu trữ và bảo vệ khóa bí mật tương ứng với khóa công khai ghi trên chứng thư. Chủ thể ở tầng này không có quyền cấp phát chứng thư cho các thực thể khác (thuộc tính mở rộng `basicConstraints` bắt buộc phải thiết lập `cA:FALSE`).

- **Bên tin cậy (Relying Party):** Là bất kỳ thực thể hoặc ứng dụng nào (như trình duyệt web máy trạm, ứng dụng xác thực) nhận chứng thư số từ Subject và cần thẩm định xem chứng thư đó có đáng tin cậy hay không. Relying party đối chiếu với danh mục Trust Anchor cấu hình sẵn trong Trust Store nội bộ để tiến hành xây dựng và xác minh đường dẫn chứng thư (Certification Path Validation Algorithm).

- **Kho lưu trữ và công bố chứng thư (Repository / Directory Service):** Là hệ thống máy chủ dịch vụ công cộng (thường chạy qua giao thức HTTP hoặc LDAP) chịu trách nhiệm lưu trữ và xuất bản các chứng thư CA, danh sách thu hồi chứng thư (CRL) hoặc cung cấp dịch vụ phản hồi trạng thái thu hồi trực tuyến (OCSP Responder) để relying party có thể truy vấn và tải về kiểm tra bất kỳ lúc nào.

Bảng 3.1 tổng hợp vai trò, loại khóa quản lý và trạng thái hoạt động của các thành phần trong hệ thống PKI.

3.1.2 Mô hình tin cậy phân cấp (Hierarchical Trust Model)

Trong hệ thống PKI chuẩn ITU-T X.509, mô hình tin cậy phổ biến và chuẩn mực nhất là **Mô hình cây phân cấp (Hierarchical Tree)**:

- **Cơ chế ủy quyền niềm tin (Trust Delegation):** Niềm tin được kế thừa theo hướng một chiều từ gốc xuống ngọn (Root → Intermediate → Leaf). Relying party chỉ cần đặt niềm tin tiên nghiệm vào Root CA nằm trong Trust Store của mình. Mọi chứng thư do Intermediate CA hợp lệ phát hành đều tự động được thừa hưởng độ tin cậy đó thông qua chuỗi chữ ký số liên tục và có thể kiểm chứng toán học.

- **Phân định phạm vi trách nhiệm (Segregation of Duties):** Mô hình cây cho phép phân nhánh quyền hạn linh hoạt theo mục đích sử dụng. Ví dụ: một

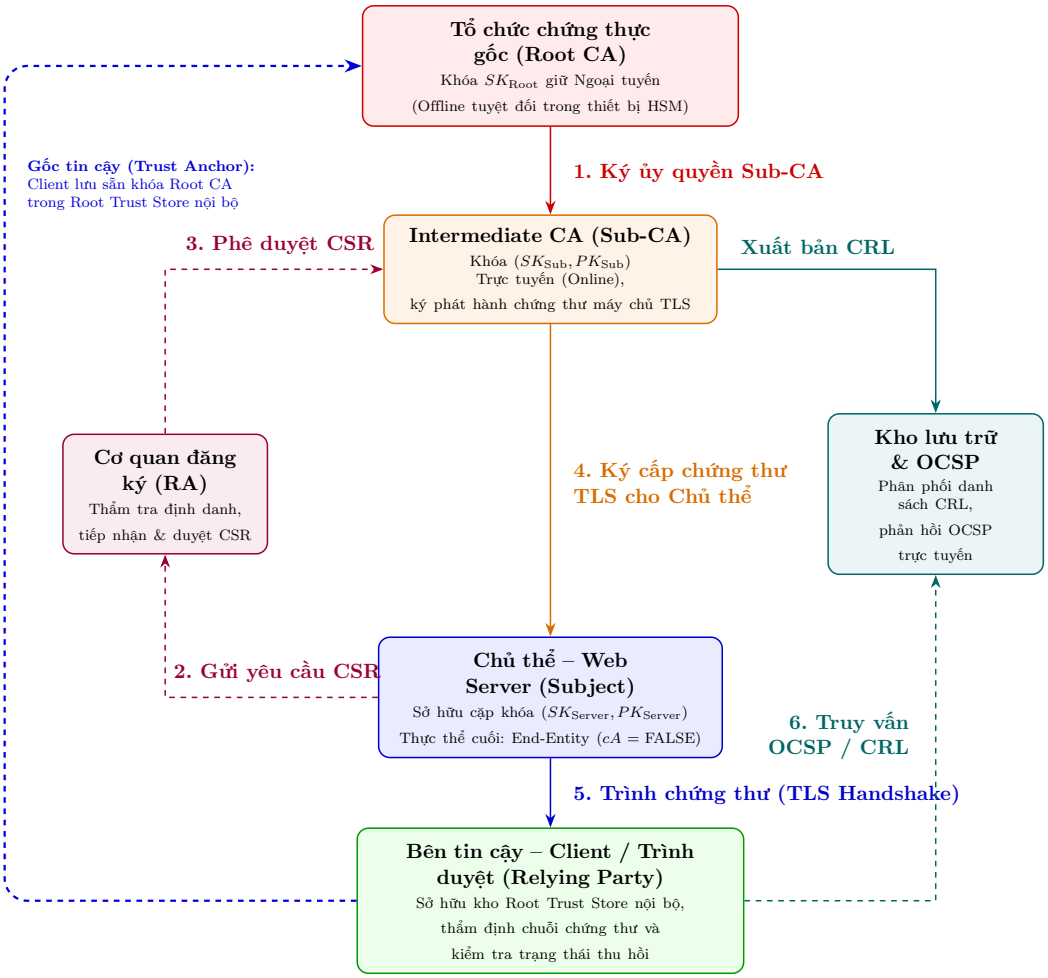
Thành phần	Khóa quản lý	Trạng thái vận hành	Chức năng chính
Trust Anchor	Khóa công khai Root CA	Tích hợp sẵn trong OS/Browser	Điểm mốc tin cậy tuyệt đối để neo chuỗi xác minh.
Root CA	SK_{Root}, PK_{Root}	Ngoại tuyến (Offline, HSM)	Ký phát hành chứng thư tự ký và ủy quyền cho Sub-CA.
Intermediate CA	SK_{Sub}, PK_{Sub}	Trực tuyến (Online)	Ký phát hành chứng thư cho End-entity, ký danh sách CRL.
RA	Khóa xác thực danh tính	Trực tuyến	Thẩm tra định danh, duyệt yêu cầu trước khi gửi sang CA.
Chủ thể (Subject)	SK_{Entity}, PK_{Entity}	Trực tuyến (Web/Client)	Nắm giữ khóa bí mật, dùng chứng thư để chứng minh danh tính.
Bên tin cậy (RP)	Sở hữu Trust Store	Trực tuyến (Client)	Thẩm định đường dẫn chứng thư, kiểm tra trạng thái thu hồi.
Kho lưu trữ (Repo)	Không giữ khóa ký	Trực tuyến (HTTP, LDAP)	Lưu trữ, xuất bản chứng thư CA, CRL và dịch vụ OCSP.

Bảng 3.1: Tổng hợp vai trò và đặc điểm vận hành của các thành phần trong PKI.

Intermediate CA chuyên trách ký cấp chứng thư cho Server TLS, một nhánh khác chuyên ký cấp mã nguồn (Code Signing), và một nhánh độc lập phục vụ danh tính cá nhân hoặc xác thực người dùng (Client Authentication).

- **Cơ chế cô lập rủi ro (Risk Isolation):** Bảo vệ Root CA ở trạng thái ngoại tuyến dài hạn; các hoạt động cấp phát tần suất cao và dễ phát sinh rủi ro trên mạng đều do Intermediate CA đảm nhiệm. Khi có sự cố lộ khóa hoặc thỏa hiệp an ninh tại một nhánh, quản trị viên chỉ cần thu hồi chứng thư của Intermediate CA tương ứng mà không làm ảnh hưởng đến các nhánh dịch vụ khác và không buộc người dùng toàn cầu phải cập nhật lại Root Trust Store.

Hình 3.1 minh họa tổng thể mối quan hệ tương tác, luồng dữ liệu cấp phát và quy trình xác thực giữa các thành phần trong mô hình PKI phân cấp.



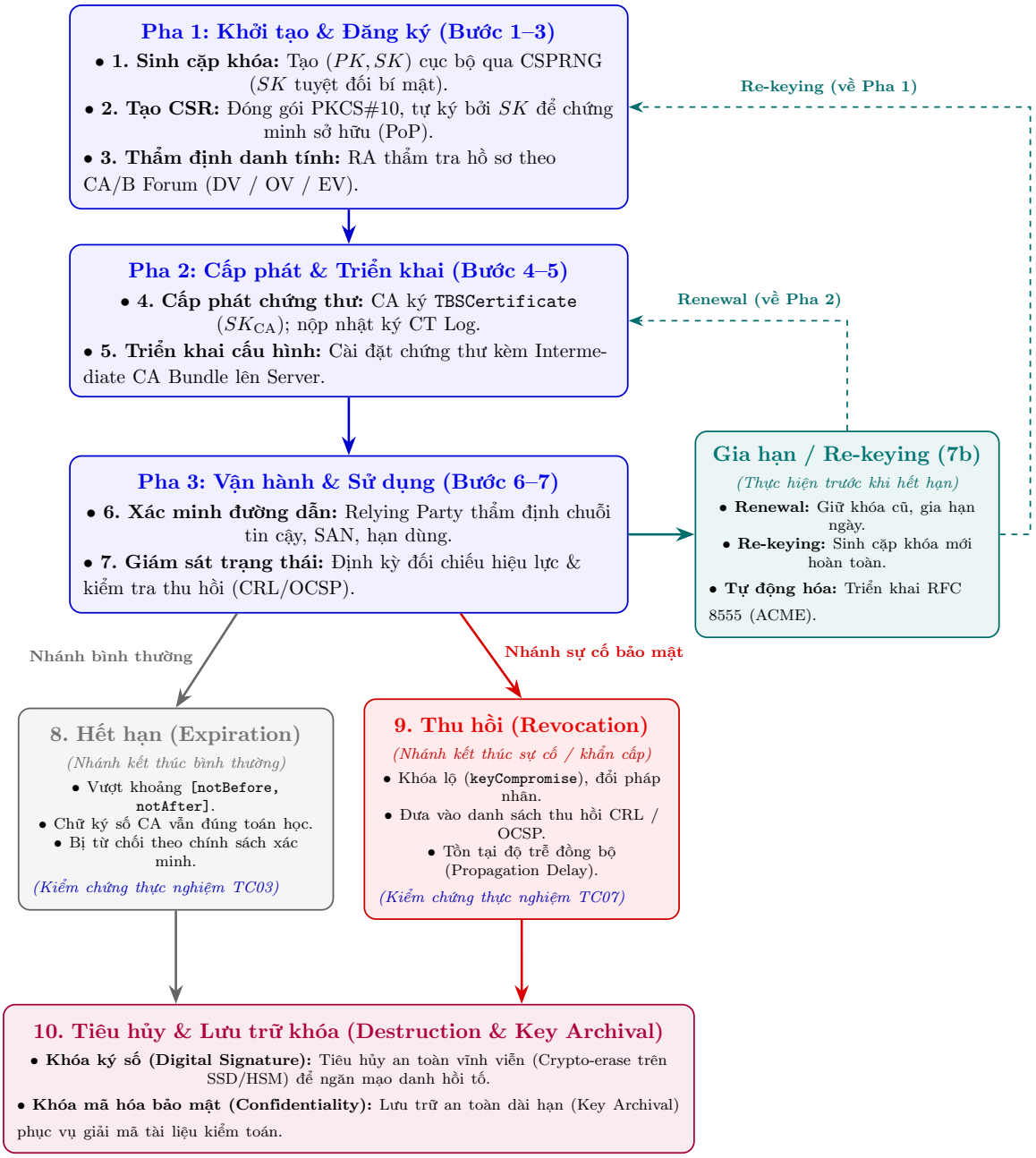
Hình 3.1: Kiến trúc các thành phần và luồng dữ liệu cấp phát, xác thực trong mô hình PKI phân cấp.

3.2 Vòng đời chứng thư

Trong khi Mục 2.1.2 đã trình bày về vòng đời của khóa mật mã (tập trung vào sự an toàn vật lý và toán học của khóa), Mục 3.2 tập trung vào vòng đời của chứng thư số (quản lý trạng thái pháp lý, cấu trúc dữ liệu và chuỗi tin cậy). Hai khái niệm này có mối liên hệ mật thiết nhưng tách biệt nhau: một chứng thư có thể hết hạn hoặc bị thu hồi trước khi cặp khóa tương ứng bị tiêu hủy, và một cặp khóa có thể tiếp tục được sử dụng qua nhiều thế hệ chứng thư nếu áp dụng hình thức gia hạn giữ khóa (renewal). Đồng thời, các tổ chức CA cũng có vòng đời riêng với quy trình khởi tạo khóa gốc nghiêm ngặt (Key Generation Ceremony) và lộ trình luân chuyển khóa định kỳ (chi tiết xem tại Mục 3.3).

3.2.1 Các giai đoạn và nhánh rẽ trong vòng đời chứng thư

Vòng đời chứng thư X.509 gồm 10 giai đoạn có các nhánh rẽ và vòng lặp thay thế nhau, được quy hoạch thành 4 pha chính như minh họa trong Hình 3.2.



Hình 3.2: Mô hình các giai đoạn, nhánh rẽ và vòng lặp trong vòng đời chứng thư X.509.

Pha 1: Khởi tạo và đăng ký (Bước 1–3)

1. **Sinh cặp khóa (Key Generation):** Chủ thể (Subject) tự sinh cặp khóa mật mã bất đối xứng (PK, SK) trên thiết bị cục bộ bằng bộ sinh số ngẫu nhiên giả an toàn mật mã (CSPRNG). Khóa bí mật (SK) phải được bảo vệ nghiêm ngặt, tuyệt đối không gửi qua mạng cho CA hay bất kỳ bên thứ ba nào.

2. **Tạo yêu cầu ký chứng thư (CSR Generation):** Chủ thể đóng gói khóa công khai (PK) cùng thông tin định danh đề nghị (tên miền/FQDN, tổ chức) thành tệp CSR theo chuẩn RFC 2986 (PKCS#10) [3]. Chủ thể dùng chính khóa bí mật của

mình ký lên CSR để cung cấp bằng chứng sở hữu khóa (Proof of Possession – PoP). Cần nhấn mạnh: chữ ký trên CSR chỉ chứng minh thực thể gửi yêu cầu có nắm giữ khóa bí mật tương ứng với khóa công khai, hoàn toàn không chứng minh được danh tính thực tế của người gửi.

3. **Xác minh danh tính (Identity Verification):** Cơ quan đăng ký (RA) tiếp nhận CSR và thẩm tra thông tin định danh theo các quy định trong Tiêu chuẩn Baseline Requirements của CA/Browser Forum [4] và chính sách CP/CPS của CA. Tùy theo loại chứng thư, quy trình thẩm định có thể là:

   - *Domain Validation (DV):* Xác minh quyền kiểm soát đối với tên miền thông qua bản ghi DNS hoặc phản hồi HTTP.
   - *Organization Validation (OV):* Thẩm tra sự tồn tại pháp lý của tổ chức đăng ký qua cổng thông tin đăng ký doanh nghiệp chính thức.
   - *Extended Validation (EV):* Quy trình thẩm định nghiêm ngặt bổ sung nhiều thủ tục đối chiếu giấy phép kinh doanh, quyền hạn đại diện pháp luật và xác minh độc lập bằng điện thoại theo hướng dẫn của CA/Browser Forum.

Pha 2: Cấp phát và triển khai (Bước 4–5)

4. **Cấp phát chứng thư (Issuance):** CA không ký lên toàn bộ tập tin chứng thư hoàn chỉnh mà chỉ ký lên cấu trúc dữ liệu tóm lược `TBSCertificate` (To-Be-Signed Certificate) theo RFC 5280 [5].

   - CA trích xuất khóa công khai và thông tin danh tính đã duyệt, ấn định số sê-ri duy nhất và khoảng thời gian hiệu lực `[notBefore, notAfter]`.
   - *Cơ chế sao chép Extension:* CA không bắt buộc phải sao chép toàn bộ các trường hoặc extensions có trong CSR. Các phần mở rộng thiết yếu như Subject Alternative Name (SAN), Basic Constraints, Key Usage đều do cấu hình và chính sách vận hành của CA áp đặt. Trong môi trường OpenSSL, hành vi này phụ thuộc trực tiếp vào tham số `copy_extensions` trong tệp cấu hình CA (`openssl.cnf`) — nếu không bật hoặc cấu hình thiếu cẩn trọng, chứng thư phát hành sẽ bị thiếu các extension bắt buộc (như SAN), dẫn đến lỗi xác minh ở môi trường thực nghiệm (liên hệ trực tiếp tới ca kiểm thử TC04 và TC08 tại Mục 6.3).
   - Sau khi ký bằng khóa bí mật của CA (SK_{CA}), chứng thư được công bố vào kho lưu trữ (Repository) và bắt buộc phải được gửi vào các máy chủ nhật ký Certificate Transparency (CT Log) công khai theo chính sách Web PKI (chi tiết xem tại Mục 7.1).

5. **Cài đặt và triển khai (Installation / Deployment):** Chủ thể cấu hình chứng thư số cùng với tệp chuỗi chứng thư trung gian (Intermediate CA certificates / Certificate Bundle) lên máy chủ dịch vụ. Nếu thiếu chứng thư trung gian trên máy chủ, client không thể hoàn thành việc xây dựng chuỗi tin cậy dẫn tới Trust Anchor (liên hệ tới ca kiểm thử TC06 tại Chương 6).

Pha 3: Vận hành (Bước 6–7)

6. **Xác minh và sử dụng (Validation & Usage):** Khi máy chủ gửi chứng thư cho Relying Party (ví dụ trong pha bắt tay TLS 1.3 [2]), bên tin cậy sẽ kích hoạt thuật toán xác minh đường dẫn đầy đủ. Quy trình bao gồm: xây dựng chuỗi dẫn tới Trust Anchor đã cấu hình, kiểm tra chữ ký từng mắt xích, thẩm định tính hợp lệ của Basic Constraints và độ sâu chuỗi (`pathLenConstraint`), đối chiếu mục đích sử dụng khóa (Key Usage/Extended Key Usage), khớp tên máy chủ (SAN), và kiểm tra thời hạn cùng trạng thái thu hồi. Chi tiết toàn bộ thuật toán được phân tích chuyên sâu tại Mục 4.2.

7. **Gia hạn (Renewal / Re-keying):** Trước khi chứng thư mãn hạn, chủ thể thực hiện gia hạn để duy trì kết nối liên tục:

   - Nếu thực hiện *Renewal*, chủ thể tái sử dụng cặp khóa cũ và chỉ xin cấp chứng thư mới với thời hạn sử dụng mới.
   - Nếu thực hiện *Re-keying*, chủ thể quay trở lại Bước 1 để tạo cặp khóa hoàn toàn mới.

   Trong thực tế Web PKI, CA/Browser Forum liên tục thắt chặt và rút ngắn thời hạn hiệu lực tối đa của chứng thư TLS máy chủ công cộng (nhằm giảm thiểu thời gian tổn thương khi lộ khóa), kéo theo sự bắt buộc phải ứng dụng các giao thức tự động hóa như ACME (RFC 8555) [6] (phân tích chi tiết tại Mục 7.2).

Pha 4: Kết thúc vòng đời (Bước 8–10: Nhánh rẽ thay thế và Tiêu hủy)

8. **Hết hạn (Expiration):** Chứng thư không còn vượt qua bước kiểm tra thời hạn hiệu lực nếu thời điểm xác minh nằm ngoài khoảng `[notBefore, notAfter]` quy định trong cấu trúc chứng thư. Cần lưu ý rằng: chữ ký số của CA trên một chứng thư đã hết hạn vẫn hoàn toàn đúng về mặt toán học. Việc từ chối chứng thư phụ thuộc chặt chẽ vào chính sách xác minh và tính chính xác của đồng hồ hệ thống phía relying party; một client bị sai lệch đồng hồ hoặc cấu hình lỏng lẻo bỏ qua cờ kiểm tra thời gian vẫn có thể chấp nhận chứng thư này. Luận điểm này minh chứng thực nghiệm cho giả thuyết H1 và được kiểm chứng qua ca kiểm thử TC03 (Mục 6.3).

9. **Thu hồi chứng thư (Revocation):** Là nhánh rẽ kết thúc khẩn cấp thay thế cho việc hết hạn tự nhiên. Khi phát sinh sự cố, CA sẽ đưa số sê-ri của chứng thư vào danh sách thu hồi kèm theo mã lý do quy chuẩn theo RFC 5280 [5], tiêu biểu như:

   - `keyCompromise` (khóa bí mật bị lộ/thỏa hiệp),
   - `cACompromise` (khóa của CA bị xâm nhập),
   - `affiliationChanged` (chủ thể thay đổi quan hệ công tác/pháp nhân),
   - `superseded` (chứng thư đã được thay thế bằng chứng thư mới),
   - `cessationOfOperation` (dịch vụ ngừng hoạt động hoàn toàn).

   Độ trễ thu hồi (Propagation Delay): Việc thu hồi không có hiệu lực tức thời đối với mọi client. Relying party chỉ biết chứng thư bị thu hồi khi danh sách CRL mới được định kỳ phát hành và tải về thành công (phụ thuộc vào các trường `thisUpdate` và

`nextUpdate`), hoặc thông qua truy vấn OCSP trực tiếp (phân tích sâu tại Mục 4.3 và kiểm chứng qua ca kiểm thử TC07).

10. **Tiêu hủy và lưu trữ khóa (Destruction & Key Archival):**

    - *Khóa ký số:* Khi chứng thư hết hạn hoặc bị thu hồi và không còn giá trị sử dụng, khóa bí mật dùng cho chữ ký số phải bị tiêu hủy vĩnh viễn. Trên các ổ cứng thể rắn (SSD) hay bộ nhớ flash hiện đại, các lệnh xóa file thông thường của hệ điều hành không đảm bảo dữ liệu vật lý bị triệt tiêu do cơ chế Wear Leveling; vì vậy cần áp dụng các cơ chế xóa an toàn bằng mật mã (Crypto-erase) hoặc phá hủy trên các phân vùng bảo mật của phần cứng chuyên dụng (HSM/TPM).
    - *Khóa mã hóa dữ liệu:* Ngược lại với khóa ký số, nếu một cặp khóa từng được sử dụng để mã hóa lưu trữ tài liệu dữ liệu lâu dài (Confidentiality key), khóa bí mật giải mã có thể phải được đưa vào quy trình lưu trữ an toàn dài hạn (Key Archival) dưới sự bảo vệ của chính sách sao lưu nghiêm ngặt, nhằm phục vụ công tác giải mã kiểm toán trong tương lai ngay cả khi chứng thư liên kết đã hết hiệu lực.

3.2.2 Phân biệt Yêu cầu ký chứng thư (CSR) và Chứng thư số đã phát hành

Để tránh nhầm lẫn giữa định dạng yêu cầu đăng ký và đối tượng chứng thực, Bảng 3.2 đối chiếu bản chất kỹ thuật giữa tệp CSR (RFC 2986 [3]) và chứng thư số X.509 v3 (RFC 5280 [5]):

Tiêu chí phân định	**Yêu cầu ký chứng thư (CSR – PKCS#10)**	**Chứng thư số X.509 v3**
Bản chất kỹ thuật	Cấu trúc dữ liệu chứa thông tin đề nghị và khóa công khai do chủ thể tự tạo ra.	Cấu trúc dữ liệu có chữ ký số của CA, liên kết định danh với khóa công khai theo quy trình CP/CPS.
Thực thể thực hiện ký	Ký bởi chính khóa bí mật của chủ thể (SK_{subject}).	Ký bởi khóa bí mật của tổ chức cấp phát (SK_{CA}).
Dữ liệu được ký	Thông tin danh tính yêu cầu và trường khóa công khai (`SubjectPublicKeyInfo`).	Cấu trúc dữ liệu chuẩn hóa `TBSCertificate` (To-Be-Signed Certificate) của CA.
Ý nghĩa của chữ ký	Chỉ chứng minh thực thể gửi yêu cầu có nắm giữ khóa bí mật tương ứng (Proof of Possession – PoP); không chứng minh danh tính.	Xác nhận CA đã thẩm định thông tin theo chính sách vận hành và liên kết danh tính với khóa công khai.
Quyết định về Extensions	Chỉ mang tính chất đề xuất từ phía client.	Do CA toàn quyền ấn định hoặc chọn lọc (qua cờ cấu hình như `copy_extensions` trong OpenSSL).
Phạm vi sử dụng	Chỉ dùng để nộp cho CA/RA trong pha đăng ký cấp phát.	Dùng trong giao thức truyền thông (TLS) để relying party xác thực chuỗi tin cậy.

Bảng 3.2: Phân biệt bản chất kỹ thuật giữa Yêu cầu ký chứng thư (CSR – RFC 2986) và Chứng thư số X.509 v3 (RFC 5280).

3.3 Chính sách vận hành

Một hạ tầng khóa công khai (PKI) không chỉ bao gồm các thuật toán mật mã và giao thức kỹ thuật, mà còn phụ thuộc cốt lõi vào hệ thống chính sách và quy trình vận hành bảo đảm mức độ tin cậy. Về mặt cấu trúc tài liệu, RFC 3647 [7] cung cấp một khung dàn bài chuẩn hóa gồm 9 phần lớn, liệt kê danh mục các chủ đề kỹ thuật, an ninh và quản trị mà một CA cần đặc tả. Cần lưu ý rằng các ký hiệu số mục được dẫn chiếu trong Mục 3.3 này (như mục 3, 5.2, 5.4, 6.2.2, 8, 9) là số mục trong dàn bài chuẩn của tài liệu CP/CPS theo RFC 3647, không phải số mục điều khoản của chính bản thân văn bản RFC 3647. Bản thân RFC 3647 chỉ đóng vai trò phân loại và định hướng cấu trúc nội dung; các tiêu chí kỹ thuật cụ thể hay mức độ ràng buộc thực tế sẽ do CA tự xác định hoặc phải tuân thủ theo tiêu chuẩn của các bên quản lý kho khóa gốc (Root Store Policies) và các tổ chức quản lý ngành như CA/Browser Forum [4].

3.3.1 Phân định vai trò giữa CP và CPS

Khung dàn bài RFC 3647 phân chia hai tầng tài liệu chính sách:

- **Chính sách Chứng thư (Certificate Policy – CP):** Xác định các quy tắc về khả năng áp dụng của một nhóm chứng thư cho một cộng đồng người dùng cụ thể hoặc lớp ứng dụng có chung yêu cầu an ninh. CP mang tính định hướng cấp cao, làm rõ mục đích sử dụng và mức độ bảo đảm mà CA cam kết hướng tới bên tin cậy (Relying Party). Bản thân CP không tự là hợp đồng pháp lý hoàn chỉnh; hiệu lực ràng buộc thực tế thường được thiết lập qua thỏa thuận thuê bao (Subscriber Agreement) hoặc thỏa thuận bên tin cậy (Relying Party Agreement) có dẫn chiếu đến CP đó.
- **Tuyên bố Thực hành Chứng thực (Certification Practice Statement – CPS):** Đặc tả chi tiết các biện pháp kỹ thuật, quy trình thủ tục và cơ chế kiểm soát cụ thể mà một CA áp dụng để hiện thực hóa các yêu cầu được nêu trong một hoặc nhiều CP tương ứng.

Mối liên kết kỹ thuật và thực tiễn triển khai: Về mặt kỹ thuật theo chuẩn RFC 5280 [5], CP được định danh trên chứng thư số thông qua một mã định danh đối tượng (OID) đặt trong phần mở rộng `certificatePolicies`, có thể đi kèm một đường dẫn liên kết tĩnh (CPS URI) trỏ trực tiếp đến tài liệu thực hành của CA. Trên thực tế, theo quy định trong Baseline Requirements của CA/Browser Forum [4] (Mục 2.2), nhiều CA công cộng hiện nay lựa chọn cấu trúc gộp chung cả hai vai trò này vào một tài liệu duy nhất mang tên Certificate Policy and Certification Practice Statement (CP/CPS), được xây dựng bám sát 9 mục của dàn bài RFC 3647.

Lưu ý tránh nhầm lẫn trong thực nghiệm: Trong tệp cấu hình của công cụ OpenSSL (`openssl.cnf`), chỉ thị `policy = policy_strict` (hoặc `policy_loose`) chỉ đơn thuần là quy tắc kỹ thuật cấp thấp nhằm đối chiếu sự trùng khớp của các trường tên phân biệt (Distinguished Name – DN) giữa yêu cầu cấp phát (CSR) và chứng thư CA. Chỉ thị này hoàn toàn không phải là một Certificate Policy (CP) theo định nghĩa của chuẩn RFC 3647.

3.3.2 Quản lý và bảo vệ khóa bí mật của CA (Mục 6 của dàn bài RFC 3647)

Mục 6 (Technical Security Controls) trong dàn bài RFC 3647 liệt kê các chủ đề kỹ thuật mà CPS cần làm rõ, bao gồm việc tạo sinh cặp khóa, bảo vệ khóa bí mật của CA và quản lý vòng đời khóa:

- **Bảo vệ khóa bằng phần cứng:** Trong thực hành của các CA công cộng theo chuẩn Baseline Requirements [4] (Mục 6.2.7), khóa bí mật của Root CA và Intermediate CA ký phát thường được quy định phải tạo sinh và lưu trữ trong các thiết bị mật mã phần cứng chuyên dụng (Hardware Security Module – HSM) đạt các chứng nhận an toàn như FIPS 140-2/140-3 (thông thường từ Level 2 hoặc Level 3) nhằm hạn chế nguy cơ trích xuất khóa bí mật dưới dạng bản rõ.
- **Kiểm soát nhiều người (Multiperson Control – Mục con 6.2.2 của dàn bài RFC 3647):** Nhằm ngăn chặn hành vi lạm quyền của một cá nhân đơn lẻ, các CA thường áp dụng cơ chế phân mảnh bí mật với ngưỡng m-trên-n (như thuật toán Shamir's Secret Sharing, ví dụ yêu cầu kích hoạt đồng thời của 3 trên 5 thẻ khóa vật lý) đối với các thao tác nhạy cảm như kích hoạt khóa CA, ký phát chứng thư trung gian hoặc khôi phục sao lưu.
- **Nghi thức tạo khóa (Key Generation Ceremony):** Khóa bí mật của CA cấp cao thường được khởi tạo theo một nghi thức chính thức diễn ra trong môi trường an toàn vật lý được cách ly mạng, có nhân sự giám sát độc lập và được lập biên bản ghi nhận đầy đủ nhằm phục vụ công tác kiểm toán.

3.3.3 Phân quyền và các biện pháp kiểm soát thủ tục (Mục 5.2 của dàn bài RFC 3647)

Mục 5.2 trong dàn bài RFC 3647 có tiêu đề là Procedural Controls (các biện pháp kiểm soát thủ tục), liệt kê các yêu cầu mà CPS cần đặc tả về vai trò tin cậy (Trusted Roles), số lượng nhân sự cho mỗi tác vụ và nguyên tắc tách biệt nhiệm vụ:

- **Các vai trò tin cậy phổ biến:** Khung RFC 3647 không ấn định sẵn tên gọi chức danh, nhưng thực tiễn công nghiệp thường phân tách thành các vai trò độc lập điển hình như:
  - *Quản trị viên (Administrator):* Cài đặt, bảo trì hạ tầng mạng, máy chủ và phần mềm nền tảng.
  - *Nhân viên vận hành CA (CA Operator):* Tiếp nhận hồ sơ xác minh, thực hiện các thao tác cấp phát và thu hồi chứng thư số.
  - *Cán bộ kiểm toán (Audit Officer):* Độc lập hoàn toàn với nhóm kỹ thuật/vận hành, chịu trách nhiệm lưu trữ và giám sát nhật ký an ninh.
  - *Cán bộ an ninh (Security Officer):* Quản lý kiểm soát an ninh vật lý và cấp phát quyền truy cập thiết bị HSM.
- **Tách biệt nhiệm vụ và kiểm soát kép:** CPS cần làm rõ nguyên tắc một nhân sự không được phép kiêm nhiệm các vai trò mâu thuẫn lợi ích (đặc biệt là giữa người

vận hành hệ thống và người giám sát nhật ký). Những thao tác trọng yếu thường yêu cầu cơ chế kiểm soát kép (Dual Control), đòi hỏi sự hiện diện và đồng thuận của tối thiểu hai cá nhân có thẩm quyền.

3.3.4 Ghi nhận nhật ký và đánh giá tuân thủ (Mục 5.4 và Mục 8 của dàn bài RFC 3647)

- **Nhật ký kiểm toán (Mục 5.4 của dàn bài RFC 3647):** CPS cần xác định danh mục các sự kiện phải ghi log (khởi động/dừng dịch vụ, truy cập quản trị, tạo khóa, phát hành chứng thư, tạo CRL) kèm nhãn thời gian tin cậy. Dữ liệu nhật ký được khuyến nghị sao lưu định kỳ vào các phân vùng lưu trữ khó sửa đổi hoặc hệ thống thu thập log tập trung được phân quyền độc lập.
- **Đánh giá tuân thủ (Mục 8 của dàn bài RFC 3647):** RFC 3647 liệt kê các chủ đề về tần suất đánh giá, phạm vi kiểm toán và tư cách của tổ chức đánh giá. Theo chính sách quản lý Root Store và quy định của CA/Browser Forum [4], các CA công cộng thực tế phải trải qua các đợt kiểm toán định kỳ hằng năm bởi các tổ chức kiểm toán độc lập đủ điều kiện theo các chuẩn mực như WebTrust for CA hoặc ETSI EN 319 411.
- **Bài học từ sự cố DigiNotar (Fox-IT, 2011) [1]:** Báo cáo điều tra pháp y của Fox-IT về vụ xâm nhập nhà cấp phát chứng thư số DigiNotar cho thấy đơn vị này đã vượt qua các kỳ kiểm toán định kỳ trước đó, nhưng trên thực tế hệ thống mạng vẫn tồn tại lỗ hổng nghiêm trọng: hạ tầng CA không được phân tách mạng đúng chuẩn, không áp dụng HSM chặt chẽ, mật khẩu quản trị yếu và kẻ tấn công có thể can thiệp xóa nhật ký kiểm toán mà không bị phát hiện. Sự cố này chứng minh rằng văn bản chính sách CP/CPS và chứng chỉ kiểm toán chỉ là điều kiện cần chứ không phải điều kiện đủ; an toàn của hệ thống PKI phụ thuộc trực tiếp vào việc thực thi giám sát kỹ thuật liên tục và phòng thủ theo chiều sâu.

3.3.5 Đối chiếu chính sách CA thực tế và môi trường thực nghiệm của nhóm

Chính sách vận hành hoàn chỉnh của một CA trong môi trường sản xuất không thể được suy diễn hay đại diện chỉ thông qua các kịch bản thực nghiệm trong phòng lab. Bảng 3.3 tổng hợp sự khác biệt cơ bản giữa yêu cầu của một CA thực tế theo khung RFC 3647 và môi trường thử nghiệm đã được triển khai:

Sự đối chiếu trên làm rõ rằng các ca kiểm thử từ TC01 đến TC10 được thực hiện trong báo cáo chỉ nhằm mục đích chứng minh tính đúng đắn của logic kỹ thuật, định dạng X.509 và giải thuật xác thực chuỗi chứng thư (Path Validation) theo chuẩn RFC 5280 [5]. Các kết quả này hoàn toàn không phản ánh mức độ an toàn vận hành, năng lực phòng vệ hay tính tuân thủ quy trình an ninh mạng mà một CA thực tế thường phải thiết lập.

Chủ đề theo dàn bài RFC 3647	**Yêu cầu đặc tả trong CPS của CA thực tế**	**Triển khai trong bài lab thực nghiệm của nhóm**
Xác minh danh tính (Mục 3)	Quy trình thẩm định hồ sơ pháp lý chặt chẽ theo phân hạng chứng thư (DV, OV, EV), đối chiếu cơ sở dữ liệu doanh nghiệp và xác minh tên miền thực tế.	Bỏ qua hoàn toàn quy trình xác minh thực tế; thông tin chủ thể (Subject DN) được tự gán trực tiếp qua tệp cấu hình hoặc lệnh OpenSSL.
Kiểm soát thủ tục & vai trò tin cậy (Mục 5.2)	Phân tách chặt chẽ tối thiểu 4 vai trò độc lập; không cho phép kiêm nhiệm; áp dụng cơ chế kiểm soát kép (Dual Control) cho các tác vụ nhạy cảm.	Toàn bộ thao tác (sinh khóa, tạo CSR, ký chứng thư, thu hồi) do một cá nhân duy nhất thực hiện trên cùng một tài khoản hệ điều hành.
Nhật ký kiểm toán (Mục 5.4)	Ghi vết tự động, toàn diện các sự kiện an ninh với nhãn thời gian tin cậy; chuyển log về máy chủ tập trung hoặc lưu trữ bất biến.	Chỉ dựa vào tệp văn bản thô `index.txt` và `serial` của OpenSSL; không có cơ chế lưu vết truy cập quản trị hay chống chỉnh sửa log.
Bảo vệ khóa bí mật của CA (Mục 6.2, 6.2.2)	Lưu trữ trong thiết bị mật mã phần cứng chuyên dụng (HSM); kích hoạt bằng cơ chế chia sẻ bí mật ngưỡng nhiều người (m-trên-n).	Khóa bí mật của Root CA và Intermediate CA lưu trực tiếp dưới dạng tệp tin phần mềm (`.key`) trên ổ đĩa máy tính, chỉ bảo vệ bằng mật khẩu phần mềm.
Đánh giá tuân thủ (Mục 8)	Định kỳ kiểm toán độc lập hằng năm theo các chuẩn mực quốc tế (WebTrust, ETSI) để duy trì chứng thư trên Root Store.	Không có quy trình đánh giá tuân thủ; là hệ thống tự tạo và tự tin cậy cục bộ phục vụ học thuật.
Pháp lý và trách nhiệm (Mục 9)	Quy định rõ về quỹ bảo hiểm, trách nhiệm tài chính với bên tin cậy và cơ chế giải quyết tranh chấp.	Hoàn toàn không phát sinh cam kết pháp lý hay ràng buộc tài chính.

Bảng 3.3: So sánh đối chiếu giữa khung dàn bài RFC 3647, triển khai CA thực tế và bài lab của nhóm.

Chương 4

X.509, chuỗi tin cậy và cơ chế xác thực

4.1 Cấu trúc chứng thư X.509 v3

Cần giải thích serial number, issuer, subject, validity, Subject Public Key Info, SAN, Basic Constraints, Key Usage và Extended Key Usage theo RFC 5280 [5]. Đưa ảnh chụp `openssl x509 -text` của chứng thư trong lab sau khi chạy.

4.2 Xây dựng và xác minh đường dẫn

Minh họa Root CA → Intermediate CA → server. Cần mô tả chữ ký từng mắt xích, trust anchor, hiệu lực, mục đích sử dụng, tên máy chủ và trạng thái thu hồi. Root CA tự ký chỉ trở thành trust anchor khi client cấu hình tin cậy nó.

4.3 Thu hồi và trạng thái chứng thư

Cần so sánh CRL và OCSP; trích RFC 5280 và RFC 6960 [5, 8]. Phân biệt trạng thái OCSP *good* với việc chứng thư vượt qua mọi bước validation.

4.4 Liên hệ TLS

Cần diễn giải vai trò của chứng thư và CertificateVerify trong TLS 1.3 [2]; giải thích đâu là kiểm tra do ứng dụng thực hiện và đâu là chính sách riêng của trình duyệt.

Chương 5

Phân tích bảo mật, mô hình tấn công và so sánh

5.1 Tài sản, đối thủ và rủi ro

Cần lập bảng tài sản cần bảo vệ (khóa CA, khóa máy chủ, trust store, quy trình xác minh) và các mối đe dọa: lộ khóa, CA cấp sai / bị xâm nhập (rogue certificates, phân tích sâu trường hợp DigiNotar [1]), MITM, chứng thư hết hạn, kiểm tra thu hồi không đầy đủ.

5.2 So sánh các cơ chế tin cậy và thu hồi

Cần so sánh CA PKI, Web of Trust, TOFU theo giả định tin cậy; sau đó so sánh CRL, OCSP và chứng thư thời hạn ngắn theo độ mới, chi phí, khả dụng. Không kết luận một mô hình luôn vượt trội trong mọi môi trường.

5.3 Giới hạn của chữ ký hợp lệ

Cần liên hệ với kết quả ở Chương 6: một chữ ký đúng không tự chứng minh trust anchor, hostname, hiệu lực, EKU hoặc trạng thái thu hồi đều thỏa chính sách client.

Chương 6

Thiết kế và đánh giá thực nghiệm

6.1 Giả thuyết và môi trường

H1: chữ ký hợp lệ chưa đủ để chứng thư được tin cậy. H2: thay đổi thời hạn, hostname, trust anchor hoặc trạng thái thu hồi làm thay đổi quyết định xác minh. H3: các cơ chế xác minh có giới hạn và chi phí vận hành khác nhau. Cần điền phiên bản OpenSSL, hệ điều hành, ngày chạy và thiết bị thực tế.

6.2 Mô hình và quy trình

Lab sử dụng Root CA → Intermediate CA → chứng thư máy chủ. Quy trình tái lập được ghi trong `demo/README.md`. Cần bổ sung sơ đồ do nhóm tự xây dựng, giải thích extension của từng chứng thư và chính sách xác minh được bật.

6.3 Test cases và kết quả

Bảng 6.1: Bộ kiểm thử dự kiến; cột quan sát chỉ điền sau khi chạy lab

ID	Điều kiện	Kỳ vọng
TC01	Chuỗi tin cậy, hostname và mục đích phù hợp	PASS
TC02	CA phát hành không được tin cậy	FAIL
TC03	Thời điểm kiểm tra sau ngày hết hạn	FAIL
TC04	Hostname không khớp SAN	FAIL
TC05	Chữ ký chứng thư bị sửa	FAIL
TC06	Thiếu chứng thư Intermediate CA	FAIL
TC07	Đã thu hồi, bật kiểm tra CRL	FAIL
TC08	EKU không cho phép TLS server	FAIL
TC09	Còn hiệu lực, chưa thu hồi tại thời điểm kiểm tra	PASS
TC10	Chuỗi hợp lệ nhưng không dẫn tới trust anchor được cấu hình	FAIL

Sau khi chạy `make demo-test`, lấy `demo/out/results.tsv`, kiểm tra từng lệnh/exit

code và thêm bảng *kết quả quan sát* với trích đoạn output. Không coi kỳ vọng ở bảng trên là bằng chứng thực nghiệm.

6.4 Thảo luận và hạn chế

Cần trả lời H1–H2 dựa trên dữ liệu. H3 đòi hỏi phép đo hoặc phương pháp so sánh riêng; nếu nhóm không làm, ghi rõ chưa kiểm chứng thực nghiệm. Lab CA nội bộ và OpenSSL không đại diện cho toàn bộ Web PKI; kiểm tra CRL ở đây được bật tường minh và không tương đương hành vi mặc định của mọi client. Nếu làm benchmark, ghi phần cứng, thông số khóa, số lần lặp, trung vị và độ lệch chuẩn.

Chương 7

Ứng dụng và hướng phát triển PKI

7.1 Ứng dụng và Certificate Transparency

Cần liên hệ HTTPS/TLS, ký tài liệu, code signing và thiết bị. Giải thích Certificate Transparency giúp phát hiện việc cấp phát sai qua cơ chế nhật ký/giám sát, không tự ngăn chặn CA cấp sai [9].

7.2 Tự động hóa và hậu lượng tử

Giới thiệu ACME theo RFC 8555 [6]; phân biệt các hướng ký hậu lượng tử với cơ chế thiết lập khóa. Kiểm chứng lại mọi mốc quy định hiện hành từ nguồn chính thức trước khi đưa vào báo cáo cuối.

Kết luận và hướng phát triển

Cần viết sau khi có số liệu: trả lời câu hỏi trung tâm và RQ1–RQ4, đối chiếu H1–H2 với kết quả quan sát; chỉ kết luận về H3 nếu có bằng chứng riêng. Nêu giới hạn của lab và hướng phát triển khả thi. Không tuyên bố đóng góp mới vượt quá phạm vi thử nghiệm.

Tài liệu tham khảo

[1] Jurrien R. Prins and Jelle Schipper. Diginotar certificate authority breach "operation black tulip". Technical report, Fox-IT Whitepaper, 2011.

[2] Eric Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report 8446, RFC Editor, 2018.

[3] Magnus Nystrom and Burt Kaliski. Pkcs #10: Certification request syntax specification version 1.7. Technical Report 2986, RFC Editor, 2000.

[4] CA/Browser Forum. Baseline requirements for the issuance and management of publicly-trusted certificates, 2023.

[5] David Cooper, Stefan Santesson, Stephen Farrell, Sharon Boeyen, Russell Housley, and William Polk. Internet x.509 public key infrastructure certificate and certificate revocation list (crl) profile. Technical Report 5280, RFC Editor, 2008.

[6] Richard Barnes, Jacob Hoffman-Andrews, Daniel McCarney, and James Kasten. Automatic certificate management environment (acme). Technical Report 8555, RFC Editor, 2019.

[7] Santosh Chokhani, Warwick Ford, Randy Sabett, Charles Merrill, and Stephen Wu. Internet x.509 public key infrastructure certificate policy and certification practices framework. Technical Report 3647, RFC Editor, 2003.

[8] Stefan Santesson, Michael Myers, Rich Ankney, Ambarish Malpani, Slava Galperin, and Carlisle Adams. X.509 internet public key infrastructure online certificate status protocol - ocsp. Technical Report 6960, RFC Editor, 2013.

[9] Ben Laurie, Eran Messeri, and Rob Stradling. Certificate transparency version 2.0. Technical Report 9162, RFC Editor, 2021.